

"FortiBleed" — making sense of the Fortinet credential-exposure campaign

A plain-language field reference for FortiGate customers: what it affects, how to contain it today, the exact technical fixes, and how to stay protected against the next incident. With a banking-sector lens for Cambodia & Myanmar.

- Priority: HIGH — act now
- Type: Credential exposure — no software patch
- Mitigations available today

WHAT IT IS Credential-harvesting campaign vs. internet-facing FortiGate / SSL-VPN	FORTINET POSITION Not a new Fortinet vulnerability
AFFECTED FortiGate · FortiOS SSL-VPN (legacy password hashing)	THE FIX Access hygiene: rotate creds · MFA · lock down management
PREPARED FOR CBM customers (banking focus)	

!

HOW TO USE THIS BRIEF

This summary was prepared by the **Fortinet Cambodia & Myanmar field team** to help customers understand and act on the FortiBleed reports quickly. It consolidates Fortinet's official PSIRT guidance, the CISA hardening alert, and reputable third-party research (Arctic Wolf, Bitdefender).

It is a **field reference, not an official Fortinet PSIRT advisory and not a contractual commitment**. For authoritative and binding guidance always refer to the official Fortinet PSIRT advisory¹ and engage your Fortinet account team or FortiCare. Scale figures are third-party estimates that continue to change; confirm your own exposure with your security team before drawing conclusions.

01 Situation & impactWhat FortiBleed is, the affected functions, and the Fortinet products in scope.

02 Immediate containment & workaroundThe first-24-hours checklist from Fortinet, CISA and consultancy sources.

03 Technical remediationFirmware targets, configuration and CLI steps, detection — in SE language.

04 Staying protected & responding fasterForward posture, monitoring, and a 30-day hardening roadmap.

SECTION 01

Situation & impact: what's affected, and what isn't

In mid-June 2026, security researchers disclosed a large-scale credential-exposure campaign nicknamed “FortiBleed.” Understanding it correctly is the first step to a calm, effective response.

Despite the “-bleed” nickname, this is **not** a Heartbleed-style memory bug and **not** a new software flaw in FortiOS. Independent researchers reported that attackers harvested configuration backup files from FortiGate devices whose management or SSL-VPN interface was reachable from the public internet, then cracked the password hashes stored inside those files offline — producing working administrator and VPN credentials.^{6 7}

Fortinet's official PSIRT analysis is direct: the activity “**is not a new Fortinet vulnerability**” and is not related to any recent advisory. Fortinet attributes it to threat actors **reusing credentials from prior incidents** (referencing advisories FG-IR-26-060 and FG-IR-25-647) combined with **brute-force against devices with weak password hygiene and no multi-factor authentication (MFA)**.¹ In other words, the exposed asset is *access* — not a patchable code defect.

That distinction matters for how you respond. There is no fix to “wait for.” A device that is fully up to date but still uses old, crackable password hashing — and is reachable from the internet without MFA — remains exposed until its credentials are rotated and its access is locked down. Equally, a device whose management and VPN are already restricted to trusted networks with MFA enforced is largely *outside* the initial harvest scope.⁷

■ Affected functions & Fortinet products

Affected function	Fortinet product	What is exposed / why
Administrator authentication	FortiGate / FortiOS	Admin passwords are stored as hashes inside the device configuration. Legacy salted SHA-256 hashes can be cracked offline at scale.
SSL-VPN remote access	FortiOS SSL-VPN	Local VPN user credentials / authentication hashes can be recovered the same way, granting remote network access that “looks legitimate.”
Configuration backup / restore	FortiGate / FortiOS	The config file is the carrier — it contains the hashes. Treat every configuration backup as a secret.
Password storage (hashing)	FortiOS	Root cause. PBKDF2 hashing was introduced in 7.2.11 / 7.4.8 / 7.6.1; older builds and un-migrated accounts remain on SHA-256.
Identity integration → lateral movement	FortiGate + customer AD / LDAP	If AD/LDAP is integrated, a recovered credential can be a stepping stone into the internal network and domain.
Cloud SSO (seeding, prior CVEs)	FortiCloud SSO	Earlier, since-patched CVEs helped seed the credential set attackers are now reusing — context, not the current mechanism.

● REASSURING & ACCURATE — WHAT IS NOT AFFECTED

FortiGate inspection engine (IPS, AV, web filter, firewall policy)	No flaw involved
Devices with management & SSL-VPN restricted to trusted networks	Largely out of scope
Accounts protected by enforced MFA	Meaningfully protected
Accounts already migrated to PBKDF2 hashing	Not offline-crackable in practice

■ Quick self-check: “Am I exposed?”

If you answer “yes” to all three, treat administrator and VPN credentials on that device as **potentially exposed** and proceed to Section 02.

- 1 Internet-facing?** Is the FortiGate's admin interface (HTTPS/SSH) or SSL-VPN portal reachable directly from the public internet?
- 2 Legacy hashing?** Were the admin / local VPN passwords last set on a build older than 7.2.11 / 7.4.8 / 7.6.1, or before each admin logged in after upgrading?
- 3 No second factor?** Are any administrator or VPN accounts *without* MFA?



On the numbers

Third-party estimates of impacted devices range widely — roughly 30,000 to ~86,000 internet-facing devices across 194 countries, with some researchers suggesting about half of the internet-exposed FortiGate fleet.^{6 7} Treat these as directional, not a measure of your own risk. Your exposure depends entirely on the three checks above.

SECTION 02

Immediate containment & workaround

There is no patch to wait for — containment is about access hygiene, and you can act today. The six steps below follow Fortinet's official guidance,¹ reinforced by CISA⁵ and consultancy sources.^{6,7}

1

Terminate sessions & reset all credentials

End all active administrative and SSL-VPN sessions. Reset every Fortinet administrator, local user and VPN password — prioritising internet-facing systems — and enforce a strong password policy.

Source · **Fortinet PSIRT**, CISA

2

Enforce MFA everywhere

Turn on multi-factor authentication for *all* administrator and VPN accounts. This is the single most durable control: a reused password has no second factor to defeat. Phishing-resistant factors are preferred where available.

Source · **Fortinet PSIRT**, CISA, Arctic Wolf, Bitdefender

3

Reduce attack surface — lock down management

Take management and SSL-VPN off the open internet. This is the highest-impact mitigation and takes effect immediately, before any upgrade. See the good / better / best tiers below.

Source · **Fortinet PSIRT**, Bitdefender

4

Validate the configuration

Review firewall, VPN users and settings for unauthorised changes — ideally against a known-good backup. Watch for unfamiliar accounts named like `forticloud`, `fortiuser`, `fortinet-support`, `fortinet-tech-support`.

Source · **Fortinet PSIRT**

5

Check your logs

Look for administrator logins from unknown IPs/geographies, configuration-export events to external addresses, unexpected SSL-VPN logins, and domain-controller logs that suggest lateral movement.

Source · **Fortinet PSIRT**, Bitdefender

6

If you find an indicator — treat as compromised

Follow Fortinet's device-recovery guidance, treat any integrated AD/LDAP account as compromised, monitor for lateral movement, and engage **FortiGuard Incident Response** for a scoping call.

Source · **Fortinet PSIRT**

■ The workaround that matters most: get management off the internet

Fortinet frames management lock-down as good / better / best. Any tier is a valid emergency workaround; aim to reach “best.”¹

GOOD

Restrict by trusted hosts

Limit each admin account to known management source IPs (trusthost), so the login surface only answers your networks.

BETTER

Local-in policy

Apply a local-in policy that permits management/VPN only from defined trusted sources and drops everything else at the device itself.

BEST

Remove internet administration entirely

No administrative or SSL-VPN exposure on the WAN at all — manage out-of-band or via FortiManager, and move remote access to ZTNA.



Don't stop at “patched”

Patching related CVEs is good hygiene but does **not** close this exposure. Valid credentials survive firmware upgrades — the credential window only closes when each credential is rotated and MFA is in place.⁷

Technical remediation — firmware, configuration & CLI

For the customer's network / security team. Precise steps to migrate hashing, rotate credentials, enforce MFA and shrink the attack surface. Validate exact syntax against your running FortiOS version before applying in production.

■ Root cause in one paragraph

FortiGate stores administrator and local-user passwords as hashes inside the configuration. Older builds used **salted SHA-256** — fast, and therefore crackable offline with commodity GPU hardware. PBKDF2 (deliberately slow, offline-cracking-resistant) was introduced in **FortiOS 7.2.11, 7.4.8 and 7.6.1**. Two subtleties make the migration incomplete by default: (1) after an upgrade, an existing admin's password stays SHA-256 until *that admin logs in again*; and (2) the original SHA-256 hash is retained in a hidden old-password field for backward compatibility until it is explicitly purged.^{6 7}

■ Step 1 · Firmware targets

Upgrade to a build that supports PBKDF2 — Fortinet recommends the latest **7.4, 7.6 or 8.0** (minimum 7.2.11 / 7.4.8 / 7.6.1). Devices below these builds store all passwords as SHA-256 with no migration path until upgraded. Plan the path with the Fortinet Upgrade Path tool.⁸

● MINIMUM BUILDS FOR PBKDF2 SUPPORT	
7.2 branch	≥ 7.2.11
7.4 branch	≥ 7.4.8
7.6 branch	≥ 7.6.1
Fortinet recommendation	Latest 7.4 / 7.6 / 8.0

■ Step 2 · Migrate hashing to PBKDF2 & purge legacy hashes

After upgrading, require **every administrator to log in at least once** — this converts their hash to PBKDF2. Then purge the retained SHA-256 material. On 7.2.x / 7.4.x, enable the documented setting:^{4 6}

● FORTIOS CLI · ENFORCE PBKDF2 / PURGE OLD-PASSWORD

```
# after every admin has logged in once post-upgrade:
config system password-policy
    set login-lockout-upon-weaker-encryption enable
end
```



Why both steps are needed

The upgrade alone does not replace existing hashes; the per-admin login does the conversion, and the setting above removes the leftover SHA-256 in old-password. Do them in that order.

■ Step 3 · Rotate credentials & enforce a strong policy

● FORTIOS CLI · RESET AN ADMIN PASSWORD (RUN AS SUPER_ADMIN)

```
config system admin
    edit "<admin-name>"
        set password <new-strong-secret>
    next
end
```

● FORTIOS CLI · REPRESENTATIVE STRONG PASSWORD POLICY

```
config system password-policy
    set status enable
    set min-length 14
    set min-lower-case-letter 1
    set min-upper-case-letter 1
    set min-number 1
    set min-non-alphanumeric 1
    set expire-status enable
end
```


■ Step 4 · Restrict management to trusted hosts

● FORTIOS CLI · PER-ADMIN TRUSTED HOSTS

```
config system admin
  edit "<admin-name>"
    set trusthost1 10.0.0.0 255.255.255.0 # your mgmt subnet
    set trusthost2 <jump-host-ip> 255.255.255.255
  next
end
```

■ Step 5 · Remove administrative access from the WAN

● FORTIOS CLI · DROP ADMIN/VPN SERVICES ON THE INTERNET-FACING INTERFACE

```
config system interface
  edit "<wan-interface>"
    # keep only what you truly need; remove http/https/ssh admin from WAN
    set allowaccess ping
  next
end
# Better: enforce with a local-in policy permitting mgmt only from trusted sources,
# and deny all other inbound to the device's management services.
```

■ Step 6 · Enable MFA on admin & VPN accounts

● FORTIOS CLI · TWO-FACTOR WITH FORTITOKEN (EXAMPLE)

```
config system admin
  edit "<admin-name>"
    set two-factor fortitoken
    set fortitoken <token-serial>
    set email-to <admin@bank.example>
  next
end
```

At scale, use **FortiAuthenticator** for centralised MFA and **FortiToken** provisioning across the fleet; for remote workforce access, prefer **FortiClient + ZTNA** over an always-listening SSL-VPN portal.

■ Detection & threat-hunting (what to look for)

- Configuration-backup **export events to an external IP** — a strong signal of harvesting.
- Administrator authentication from **unfamiliar IPs or geographies**, or at unusual times.
- **New administrator accounts** created outside your normal change-control workflow.
- Changes to **logging, authentication or interface** settings outside documented windows.
- **Outbound tunnels** to unrecognised IPs, or SSL-VPN logins for known users from impossible locations.



Related CVEs to patch (context, not the root cause)

FortiCloud SSO weaknesses that helped seed earlier credential capture — CVE-2026-24858 (patched Jan 2026), CVE-2025-59718 and CVE-2025-59719 (patched Dec 2025). Patch them as good hygiene, but remember: rotation + MFA + access restriction is what closes the credential exposure.⁷

SE TALK-TRACK · HOW TO FRAME THIS WITH THE CUSTOMER'S TECHNICAL TEAM

"The good news is there's nothing to wait for — the fix is access hygiene, and it uses tools you already own. We can roll the configuration baseline across your whole fleet from FortiManager, push MFA centrally with FortiAuthenticator and FortiToken, and validate clean-up by hunting the FortiAnalyzer logs for config-export and off-geo admin events."

Positioning, not promises: anchor on what the customer controls today (rotate, MFA, lock down management), then show how FortiManager (fleet roll-out), FortiAnalyzer / FortiSIEM (hunting), FortiAuthenticator (MFA at scale) and ZTNA (retire exposed SSL-VPN) make it faster and durable. Avoid committing to remediation timelines or outcomes on Fortinet's behalf — direct binding questions to the account team and FortiCare.

SECTION 04

Staying protected & responding faster

FortiBleed is a hygiene wake-up call. The same controls that contain it also raise the cost of the next incident and shorten your response time.

■ Four durable shifts

Pillar	Make it the standard	Why it shortens the next response
Architecture	Management off the public internet for good — out-of-band or FortiManager-only; migrate remote access from SSL-VPN to ZTNA ; segment the identity tier.	Removes the internet-wide scan surface that this campaign — and the next one — starts from.
Identity	MFA everywhere, least-privilege admin, central authentication (FortiAuthenticator / AD with MFA), routine credential rotation, encrypted config-backup handling.	A leaked credential is no longer enough on its own; rotation bounds its useful life.
Hygiene baseline	Standardise on PBKDF2 , keep firmware on supported builds, and treat every configuration backup as a secret.	Closes the offline-cracking path before attackers can use it.
Visibility	Centralise logs to FortiAnalyzer / FortiSIEM ; alert on config-export, off-geo admin logins and new admin accounts; know what is internet-exposed.	Turns “did something happen?” into a same-day answer instead of a forensic project.

■ A 30-day hardening roadmap

- **NOW · 0–24H** **Contain.** Terminate sessions, rotate admin/VPN credentials, enable MFA, restrict management to trusted hosts. (Section 02.)
- **72 HOURS** **Verify & migrate.** Confirm every admin has logged in to convert to PBKDF2, purge legacy hashes, audit config against a known-good baseline, and review logs for indicators.
- **30 DAYS** **Re-architect.** Remove internet administration entirely, stand up centralised MFA, and begin the SSL-VPN → ZTNA migration. Roll the baseline fleet-wide via FortiManager.
- **ONGOING** **Monitor & rehearse.** Subscribe to FortiGuard outbreak alerts and Fortinet PSIRT, keep an incident runbook with a FortiGuard IR contact, and re-check your external attack surface on a schedule.

■ A note for banking customers

Banks are high-value targets precisely because a recovered edge credential can become a path toward identity systems and, ultimately, core banking. The controls in this brief — strong authentication / MFA, privileged-access control, comprehensive logging and retention, and timely incident handling — map cleanly to the supervisory expectations regulated institutions already work to in Cambodia (NBC) and Myanmar (CBM).

This brief does not interpret specific regulatory obligations. Coordinate exact control mappings, evidence and any notification requirements with your compliance function and your respective regulator.



The confidence message

This is a well-understood hygiene problem with a clear, achievable fix — not an un-patchable crisis. Customers who restrict management exposure and enforce MFA face meaningfully lower risk today, using capabilities they already own. Fortinet is proactively contacting impacted customers and FortiGuard Incident Response is available for scoping where needed.¹

SOURCES

References

Official Fortinet, government and reputable third-party sources used in this brief. Always defer to the official Fortinet PSIRT advisory for authoritative guidance.

- 1 Fortinet PSIRT Blog — “Analysis of Reported Credential Compromise of FortiGate Devices” (What you need to know about FortiBleed)**Carl Windsor, Fortinet · June 19, 2026
fortinet.com/blog/psirt-blogs/analysis-of-reported-credential-compromise-of-fortigate-devices

- 2 Fortinet PSIRT Advisory — FG-IR-26-060**Referenced by Fortinet as related prior-incident credential reuse
fortiguard.com/psirt/FG-IR-26-060

- 3 Fortinet PSIRT Advisory — FG-IR-25-647**Referenced by Fortinet as related prior-incident credential reuse
fortiguard.com/psirt/FG-IR-25-647

- 4 Fortinet Community — Enforcing PBKDF2 as hash function for administrator accounts (FortiOS 7.2.11+)**Fortinet technical tip / KB 220652
[community.fortinet.com · technical-tip-enforcing-pbkdf2 \(220652\)](https://community.fortinet.com/technical-tip-enforcing-pbkdf2-220652)

- 5 CISA Alert — “CISA Urges Hardening Fortinet Devices After Reports of Credential Exposure”**Cybersecurity & Infrastructure Security Agency · June 18, 2026
cisa.gov/news-events/alerts/2026/06/18/...credential-exposure

- 6 Arctic Wolf Labs — “Active FortiBleed Campaign Impacting Fortinet Devices Across 194 Countries”**Security Bulletin · June 17, 2026
arcticwolf.com/resources/blog/active-fortibleed-campaign...

- 7 Bitdefender — “Technical Advisory: FortiBleed Credential Exposure Campaign Targeting Internet-Facing Fortinet Devices”**Sean Nikkel, Bitdefender Business Insights · June 22, 2026
businessinsights.bitdefender.com/technical-advisory-fortibleed...

- 8 Fortinet — FortiGate Best Practices / Hardening Guide & Upgrade Path Tool**docs.fortinet.com
docs.fortinet.com/document/fortigate/7.6.0/best-practices/hardening · [docs.fortinet.com/upgrade-too](https://docs.fortinet.com/upgrade-tool)
l



Fortify Your Cybersecurity.™

ESCALATION PATH

Your Fortinet account team
FortiCare Support
FortiGuard Incident Response (scoping)

AUTHORITATIVE SOURCE

Fortinet PSIRT advisories
fortiguard.com/psirt
fortinet.com/blog/psirt-blogs

PREPARED BY

Fortinet Cambodia & Myanmar
Field Advisory · June 2026

Important. This document is an internal field reference prepared by the Fortinet Cambodia & Myanmar team to help customers understand publicly reported FortiBleed activity and act quickly. It summarises Fortinet's official PSIRT guidance and reputable third-party research; it is **not** an official Fortinet PSIRT advisory, a security assessment of any specific environment, or a contractual commitment. Technical commands are representative and must be validated against your running FortiOS version before use in production. For authoritative and binding guidance, refer to the official Fortinet PSIRT advisory and engage your Fortinet account team or FortiCare. © 2026 Fortinet, Inc. All product names are trademarks of their respective owners.